MEvince: Knowledge-Constrained LLM Reasoning for Technique Identification from Malware Reports

Hongyu She
Zhejiang University
Hangzhou, China
hongyushe@zju.edu.cn

Yiling He*
University College London
London, United Kingdom
heyilinge0@gmail.com

Mengda Xie
Jiangsu Police Institute
Nanjing, China
985982441@qq.com

Yiping Liu
Alibaba Group
Beijing, China
ypinglinkle@gmail.com

Xingzhi Qian
University College London
London, United Kingdom
xingzhi.qian.23@ucl.ac.uk

Zhan Qin
Zhejiang University
Hangzhou, China
qinzhan@zju.edu.cn

Lorenzo Cavallaro
University College London
London, United Kingdom
l.cavallaro@ucl.ac.uk

arXiv:2611.07486v1 [cs.CR] 5 Nov 2026

Abstract

Mapping behavioral intelligence in malware analysis reports to ATT&CK techniques supports threat analysis and defense, but reliable identification remains challenging. Supporting evidence is often scattered across long, heterogeneous reports, while closely related techniques share behavioral cues and differ only in subtle but decisive details. While large language models (LLMs) can use external knowledge to interpret reports, they may assign techniques based on plausible associations rather than sufficient evidence.

We present MEvince, a knowledge-constrained LLM reasoning framework for report-level malware technique identification. Its core is a shared behavioral representation connecting report observations to technique definitions, specifying what evidence to extract and how it supports technique mapping. This representation is built through agentic mining of technique documentation and supports two online stages: 1) *primitive-guided extraction* uses behavioral primitives to structure LLM-extracted observations, link them to source passages, and group dispersed evidence; 2) *evidence-aligned retrieval* matches this evidence to technique profiles through the same concepts, retaining likely candidates and confusable alternatives for LLM comparison of distinguishing behaviors. Controls at both stages validate evidence references and check technique-specific requirements. The representation also supports adaptation without parameter updates, where offline agentic audits diagnose concept weaknesses and refine extraction or retrieval policies.

We evaluate MEvince against 11 baselines spanning four method families using a dataset of 610 public malware reports referenced by MITRE ATT&CK. MEvince improves exact-ID F1 over the strongest baseline by 17.4%, and its concept-guided retrieval increases gold-label candidate coverage from 31.6% to 47.9%. With a small adaptation set, offline refinement yields further gains and outperforms baselines that update model parameters.

CCS Concepts

• **Security and privacy → Software and application security**.

Keywords

Cyber Threat Intelligence, Malware Report, LLM Grounding

ACM Reference Format:
Hongyu She, Yiling He, Mengda Xie, Yiping Liu, Xingzhi Qian, Zhan Qin, and Lorenzo Cavallaro. 2027. MEvince: Knowledge-Constrained LLM Reasoning for Technique Identification from Malware Reports. In *Proceedings of The ACM Web Conference 2027 (WWW '27).* ACM, New York, NY, USA, 12 pages. https://doi.org/10.1145/nnnnnnn.nnnnnnn

1 Introduction

Security vendors and incident-response teams routinely publish cyber threat intelligence (CTI) reports on the Web, documenting how malware and threat actors operate in real incidents [12]. Mapping these reports to MITRE ATT&CK techniques makes the reported observations searchable and comparable, supporting detection engineering, incident triage, and knowledge-base maintenance [41, 42]. However, reliably automating this mapping while preserving evidence provenance remains challenging. On the report side, Web reports are long and heterogeneous, mix observed behavior with background and mitigation text, and often distribute the evidence for a single technique across multiple sentences or sections. Meanwhile, on the technique side, closely related ATT&CK techniques often share behavioral cues and differ in the fine-grained details required to distinguish them.

*Corresponding Author.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
WWW '27, Dublin, Ireland
© 2027 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 978-x-xxxx-xxxx-x/YYYY/MM
https://doi.org/10.1145/nnnnnnn.nnnnnnn

Prior work generally falls into four categories: classification [37], supervised fine-tuning (SFT) [5], NER-style extraction [21], and context-driven LLM reasoning [10, 18]. Classifiers and SFT models can learn recurring label patterns, but typically require task-specific annotations and a predefined label set. NER-style systems preserve explicit mentions but struggle with implicit behaviors [3] or evidence that must be composed across a report. Recent context-driven LLM methods, such as direct prompting [18] and retrieval-augmented generation (RAG) [10], reduce the need for task-specific training. However, retrieved technique descriptions provide background knowledge rather than evidence that a behavior occurred in the report.

As our motivating analysis of a real-world malware report illustrates (Table 1), direct prompting misses distributed behavioral clues, whereas RAG recovers additional parent-level techniques but also produces substantially more false positives. These contrasting failure modes stem from two underlying gaps. First, representation mismatch separates concrete report operations from abstract ATT&CK mechanisms. Without domain knowledge specifying which behavioral primitives to preserve, extraction loses the context needed to compose dispersed clues, and text-based retrieval matches surface keywords without distinguishing closely related techniques. Second, unregulated evidence authority blurs the distinct roles of observed report spans as source evidence, technique profiles as interpretive knowledge, and retrieved candidates as unverified hypotheses, leaving models to mistake retrieval rank or plausible explanations for factual support. Together, these two gaps cause existing methods to either miss fine-grained techniques or produce unsupported overpredictions that burden analysts, motivating knowledge-constrained reasoning to govern what behavioral evidence is extracted, compared, and accepted.

We present MEvince, a knowledge-constrained LLM reasoning framework for report-level malware technique identification. The key principle is that external knowledge guides interpretation, while every assignment must be supported by observed report evidence. At the core of MEvince is a shared concept foundation built through offline agentic mining of technique description documentation, which connects report observations to technique profiles in terms of actions, objects, goals, and mechanisms. This representation supports two online stages. *Primitive-guided extraction* structures LLM-extracted observations, links them to source passages, and groups dispersed clues. *Evidence-aligned retrieval* then matches this structured evidence against technique profiles while retaining likely candidates and confusable alternatives for LLM comparison of distinguishing behaviors. To reduce hallucination, deterministic controls at both stages validate source references and enforce technique-specific evidence requirements before acceptance. To additionally support light-weight adaptation, an evidence memory module is designed to learn from labeled examples and refines candidate selection without fine-tuning model parameters.

We evaluate MEvince on public malware reports referenced by MITRE ATT&CK. MEvince achieves macro F1 scores of 0.310 at exact-ID granularity and 0.386 at parent-technique granularity, outperforming the baselines under the same evaluation setting. Controlled ablations show that concept-guided retrieval improves candidate coverage beyond evidence selection alone, while claim verification reduces false-positive assignments. Evidence-memory revision yields further gains without updating model parameters.

This work makes three contributions:

- We introduce a shared behavioral representation that connects source-linked report observations to ATT&CK technique definitions through behavioral primitives, while explicitly distinguishing observed report evidence from external knowledge and unverified hypotheses.
- We develop a knowledge-constrained reasoning pipeline that combines primitive-guided extraction and evidence-aligned retrieval under two-stage verification controls, alongside a parameter-free evidence memory that refines candidate selection.
- We systematically evaluate MEvince on 610 malware reports against 11 baselines across four method families, using controlled ablations and provenance audits to demonstrate a 17.4% exact-ID F1 gain and verifiable source traceability.

2 Background and Related Work

This section reviews existing work on report-level technique identification, with additional related work discussed in Appendix E.

2.1 CTI for TTP Identification

Cyber Threat Intelligence (CTI) reports describe adversarial behaviors, contextual information, and analyst observations in natural language, providing a rich but unstructured knowledge base for malware analysis [17, 41, 43]. A fundamental task in turning this information into actionable insights for systematic analysis is to map the reported behaviors to the MITRE ATT&CK framework [42], which organizes adversarial tactics, techniques and procedures (TTPs) into a structured knowledge base. Building on prior taxonomies [3], we organize existing methods into four representative paradigms, extending the categorization to include recent reasoning-oriented approaches enabled by large language models (LLMs).

Classification-based Methods. A common approach formulates TTP identification as multi-label classification over a label set defined by a specific ATT&CK version.[1] These methods take entire reports [25, 30], or more commonly, individual sentences [35, 37] as input and require annotations at the corresponding granularity. Earlier approaches use features such as TF–IDF with conventional classifiers [1], whereas recent systems use BERT [7] and domain-adapted encoders to obtain contextual representations for downstream classification [2, 23, 36].

NER-style Methods. Another line of work uses Named Entity Recognition (NER) [27] and rule-based NLP processing [28]. These methods extract threat actions and indicators and map them through ontologies, lexical rules, or patterns [21, 22, 45]. AttacKG [28] further models dependencies among extracted entities and uses graph matching for TTP mapping. By retaining intermediate evidence as explicit textual or structured representations, these approaches make the mapping process more interpretable.

SFT-based LLM Methods. Supervised fine-tuning (SFT) adapts generative LLMs to produce TTP predictions as text. These methods

[1]The label set varies across versions: https://attack.mitre.org/resources/versions

Table 1: Technique mappings for the njRAT report.

Method	Representative Correct Mappings	Representative Errors (FNs / FPs)	Observation
Direct	Replication Through Removable Media (T1091); PowerShell (T1059.001); Web Protocols (T1071.001); Registry Run Keys / Startup Folder (T1547.001)	16 FNs, including Query Registry (T1012), Process Discovery (T1057), Modify Registry (T1112), and Non-Standard Port (T1571); 3 FPs	Captures five salient local behaviors, but misses when the mapping depends on composing weaker evidence distributed across the report.
CTIKG	[Sub-technique Level] Adds: File Deletion (T1070.004)	15 FNs (1 fewer); 6 FPs (3 more), including Spearphishing Attachment (T1566.001), Archive via Utility (T1560.001), and Local Data Staging (T1074.001)	Preserves structured intermediates with local relations, while higher pipeline complexity does not clearly improve final mapping quality.
RAG	[Parent-technique Level] Adds: Ingress Tool Transfer (T1105); Dynamic Resolution (T1568)	18 FNs (2 more); 12 FPs (9 more), including AutoHotKey & AutoIT (T1059.010), Remote Access Tools (T1219), Active Setup (T1547.014), and Hide Infrastructure (T1665)	Recovers additional true parent-level positives, but also raises substantially more FPs, suggesting that the model tends to overcommit to retrieved candidates even when evidence is weak.

typically convert sentence-level CTI annotations into instruction-style training examples, pairing an input and task instruction with the corresponding TTP labels [5, 11]. Common backbones include Llama and Qwen [16, 44]. Compared with classification-based methods, SFT-based approaches support more flexible output formats, but the mapping usually remains end-to-end.

Context-driven LLM Methods. Context-driven methods adapt LLM behavior by refining the information supplied at inference time. Direct prompting uses security ontology-aligned instructions, sometimes supplemented with few-shot examples [6]. Retrieval-augmented generation (RAG) [26] further incorporates external ATT&CK knowledge to ground TTP mapping [10, 18]. Multi-stage systems such as CTIKG [20] segment long CTI reports and employ multiple LLM agents with dual-memory mechanisms to extract and merge entity relations. These designs reduce reliance on task-specific training and can retain intermediate clues.

2.2 Why Context-driven LLMs

The recent SoK on CTI-based TTP identification [3] finds that generative LLMs are not uniformly superior: SFT is broadly comparable to classification when labeled data is available, while training-free prompting only slightly outperforms NER baselines. Beyond benchmark accuracy, CTI-to-TTP mapping also exposes two practical tensions that motivate context-driven methods.

Supervision reliance limits adaptability. Classification and SFT-based methods depend on task-specific supervision over a fixed label space. As ATT&CK releases introduce or revise techniques, these methods face recurring maintenance to accommodate changes in the target ontology [19]. Labeled CTI data are also limited: TRAM2 covers 50 techniques in 4,070 labeled sentences from 150 reports [39]. Prior work further reports challenges in open-set settings and performance degradation when moving from sentence-level to document-level training [3]. These issues make repeated retraining difficult to sustain and motivate methods that can adapt primarily at inference time.

Evidence preservation supports analysis and refinement. The interpretation of a local cue depends on its surrounding context, and reliable mapping may require combining multiple observations. For instance, a domain, an HTTP request, and periodic beaconing may support command-and-control only when considered together. End-to-end models obscure this composition, making incorrect mappings difficult to diagnose or refine, while NER pipelines preserve limited local structure and struggle with implicit references [4, 33]. Context-driven LLMs provide a way to reason over explicit intermediate evidence, provided that the pipeline preserves and verifies it. In MEvince, each accepted technique retains its source spans and matched concepts, making both the decision and its false-positive controls inspectable.

3 From Bottlenecks to Design Insights

Despite the promise, current context-driven LLM approaches exhibit notable limitations in CTI-to-TTP mapping. In this section, we first analyze their bottlenecks through a case study, and then derive corresponding design insights.

3.1 Bottleneck Analysis

Our case study is based on a Trend Micro report on the njRAT worm [32], which describes multiple behaviors that cover 21 techniques and sub-techniques, making it useful for analyzing how current methods handle semantically dense CTI evidence. We present the results in Table 1 and discuss three main observations below.

Direct prompting remains under-constrained. Direct prompting identifies salient behaviors supported by explicit local cues, such as *Replication Through Removable Media* (T1091) directly stated as "installs a hidden copy of itself on any removable drive found on the infected system", but misses labels that require contextual interpretation or the combination of weaker clues. For example, the report states that the backdoor communicates with a DuckDNS domain over port 1177. Mapping this observation to *Non-Standard Port* (T1571) requires treating the port as part of C2 communication rather than as an isolated network detail.

Complex extraction does not directly solve mapping. CTIKG uses multiple LLM stages to extract and merge structured knowledge from long reports [20]. Compared with Direct Prompt, it yields a net gain of one correct mapping but three additional false positives. For example, it infers *Spearphishing Attachment* (T1566.001) from a statement about a malicious file arriving in the system, although the report explicitly states that its arrival mechanism is unknown. It also infers *Archive via Utility* (T1560.001) from a statement about sending stolen information to the C2 server, without evidence of archiving. These errors show that structured extraction alone does not ensure sufficient evidence for a technique assignment.

RAG supplies ontology knowledge but not decision evidence. RAG is a natural way to supply ATT&CK knowledge at inference time [10, 18], but retrieved knowledge does not ensure a better decision. In this case, RAG reduces parent-level false negatives

(12 versus 14 for Direct) but increases exact-ID false negatives (18 versus 16), recovering some families without resolving their sub-techniques. RAG also produces 12 exact-ID false positives, compared with three for Direct Prompt. This suggests that retrieval can supply relevant ontology knowledge, but does not decide whether the report contains sufficient evidence.

3.2 Design Insights

While extraction can isolate threat-relevant clues and RAG can provide external technique knowledge, the case study suggests that their current forms do not yet translate into robust gains. Our insights are to organize these components around the evidence required for a technique assignment, which are described as follows.

Insight 1: Extraction should preserve TTP-relevant primitives. Current extraction pipelines often optimize for generic entities, relations, or graph completeness. However, TTP mapping depends on more specific evidence primitives, such as an action, its target artifact, and contextual qualifiers. Extraction should therefore be designed not merely to compress the report into triples, but to preserve the behavioral evidence needed to distinguish candidate techniques and link it to the original passages.

Insight 2: RAG should retrieve over evidence-aligned representations. RAG is useful because the knowledge base provides rich technique descriptions, but retrieval quality depends heavily on the representation used for matching. Instead of retrieving candidates from raw report text alone, retrieval should be driven by the behavioral primitives extracted from the report. Representing observed behavior and candidate techniques in the same terms makes their comparison more targeted and helps distinguish techniques that share broad keywords.

Insight 3: LLM outputs require explicit false-positive control. Grounding alone is not sufficient. Our case study shows that even when relevant technique knowledge is provided, the LLM can still overcommit to weakly supported labels, leading to false positives. The final mapping stage should therefore verify whether the report provides the evidence required for each proposed technique, and similarly, generated observations should be checked against their source passages during extraction. These checks allow external knowledge to guide interpretation while keeping technique assignments grounded in the report.

4 MEvince

4.1 System Overview

Figure 1 presents the workflow of MEvince. Given a malware report, the system extracts and organizes behavioral evidence, retrieves candidate techniques for LLM assessment, and verifies the resulting claims before producing report-level technique assignments. At the core of this workflow is a concept foundation built offline from technique documentation (Section 4.2). It connects report observations with technique knowledge through a shared behavioral representation, guiding two online modules. *Primitive-guided extraction* structures behavioral observations, preserves their source spans, and groups related evidence (Section 4.3). *Evidence-aligned retrieval* uses the same concepts to retrieve likely techniques and confusable alternatives for LLM comparison (Section 4.4). Deterministic controls check evidence references after extraction and

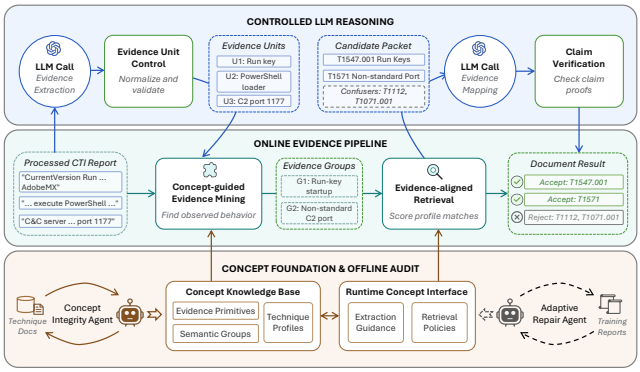

Figure 1: MEvince system architecture.

technique-specific requirements after mapping (Section 4.5). An optional adaptive block uses an evidence memory learned from labeled reports to revise candidate priority (Section 4.6).

4.2 Concept Foundation and Knowledge Base

MEvince connects reports and technique definitions through behavioral primitives that provide a common basis on which evidence mining and retrieval can be built.

Behavioral primitives. We define *anchors* as consistent concept labels mined from reports that can identify behavior or an artifact in context. The vocabulary is the disjoint union $C = C_A \dot\cup C_O \dot\cup C_G \dot\cup C_M$ of action, object, goal, and mechanism concepts. Actions and objects identify an operation and its target; goals describe its operational purpose; mechanisms capture how it is carried out. The latter two dimensions help distinguish techniques involving similar operations. Table 6 in Appendix B summarizes the four dimensions, their inventory sizes, and representative entries. For an evidence item x, we write $\Phi(x) = (A_x, O_x, G_x, M_x)$, where each component contains labels from its corresponding vocabulary. These dimensions provide a reference frame for characterizing behavioral evidence. For example, modifying a registry Run key may yield the action *modify*, the object *registry key*, the goal *persistence*, and the mechanism *registry-run-key startup*.

Knowledge organization and runtime interface. The resulting knowledge base is

$$\mathcal{K} = \big(C, \mathcal{G}, \{P_t\}_{t\in\mathcal{T}}\big), \tag{1}$$

where $\mathcal{G}$ contains reusable semantic groups, P_t represents a technique profile, and $\mathcal{T}$ indexes techniques and sub-techniques. Semantic groups capture recurring behavioral roles and combinations of primitives, such as startup persistence or payload delivery followed by execution. During online evidence mining, MEvince uses these groups to organize related report observations into *evidence groups*, which retain their members' source references and evidential status. Each technique t has a profile $P_t = (\Phi_t, S_t, R_t, Q_t)$, where Φ_t contains its concept sets, S_t its salient phrases and aliases, R_t its ontology neighbors and confusers (i.e., plausible alternative techniques that differ in their defining behavior), and Q_t its evidence requirements (i.e., artifacts, relations, or mechanisms needed to distinguish t from the alternatives).

The Runtime Concept Interface uses this knowledge base to provide extraction guidance and retrieval policies, which will be expanded in the subsequent sections. The extraction schema specifies which behavioral details the LLM should preserve. The deterministic miner then uses the vocabulary and anchors to map the extracted descriptions to concept labels. Retrieval policies rank technique profiles using Φ_t and S_t and retain relevant alternatives using R_t. The requirements in Q_t govern acceptance during verification.

Offline concept mining. To construct such a foundation, we develop a Concept Integrity Agent that uses a staged agent-script workflow. First, the agent proposes canonical primitives and their anchors. Deterministic scripts then identify unresolved phrases, overly broad labels, and missing distinctions to guide vocabulary revisions. Second, the agent composes primitives into reusable semantic groups and annotates technique profiles in the same representation. We check whether related profiles overlap too much or omit mechanisms and conditions that distinguish the techniques. Third, we test whether the miner can recognize the required concepts in report evidence and whether retrieval returns the intended techniques and plausible alternatives. If a check fails, we revise the relevant concepts or runtime rules and repeat the check.

4.3 Primitive-Guided Evidence Extraction and Mining

For each report segment s, this module extracts evidence units and organizes related observations into local groups in the shared concept space. The process is summarized as

$$Z_s = M_{\mathcal{K}}(V_{\text{ext}}(E_\theta(s; \mathcal{D}_C), s)), \tag{2}$$

where $\mathcal{D}_C$ is the extraction schema based on the primitive dimensions in Section 4.2, E_θ is the extraction LLM, V_{ext} performs evidence-unit control, and $M_{\mathcal{K}}$ is the deterministic miner that canonicalizes observations and composes local evidence using $\mathcal{K}$.

For pre-processing, MEvince partitions a report along its document structure, retaining headings, segment types, source identifiers, and offsets. Adjacent paragraphs under the same heading are combined when local context is needed. Empty fragments and indicator-dominated fragments that contain no behavioral information are skipped. Then there are three main steps.

Step 1: preserve behavioral evidence. The extraction schema defines fields for actor, action, object, goal, and mechanism to guide the LLM in preserving the behavioral information needed for subsequent mapping. For each segment, the model produces an evidence ledger $L_s = (U_s, V_s)$. Each unit $u \in U_s$ contains a minimal, complete behavioral statement, its source spans, typed fields, mapping relevance, and an evidential status. The statuses distinguish behavior reported as having occurred (*observed*), background information (*contextual*), defensive advice (*advisory*), descriptions of malware functions (*capability*), unclear or weakly supported statements (*ambiguous*), and speculation (*hypothetical*). A literal $v \in V_s$ preserves the exact text of an artifact, such as a command, registry path, filename, URL, or domain. It can also carry a short note describing how that artifact relates to the surrounding evidence.

The model keeps distinct actions as separate units and leaves unsupported fields empty. Modal statements and capability lists retain their qualifiers rather than being rewritten as executed behavior.

Step 2: align to the source and canonicalize. Evidence-unit control first normalizes and source-aligns the extracted ledger. For each unit u, the concept miner maps its extracted fields and source text to $\Phi(u)$ using the vocabulary and anchors in $\mathcal{K}$. Conservative anchor requirements limit generic matches involving words such as *access*, *create*, or *service*. High-value literals remain attached because a short command or path often supplies the mechanism needed to distinguish related techniques.

Step 3: compose local evidence. When behavioral evidence spans multiple statements, the miner groups these units and literals within a local mapping context using the reusable behavioral patterns. For example, a Run key, its value, and the referenced executable may jointly describe startup behavior. For a group g, $\Phi(g)$ combines the concepts of its members. The miner adds information about how the behavior is carried out only when the matched anchors and relations support it. The group retains the identifiers, source spans, and evidential statuses of its members. A group can be treated as observed evidence only if at least one member reports that the behavior occurred. A group containing only literals from background or advisory text remains contextual.

The same pass may record a weak hypothesis when a relation is plausible but incomplete. For example, background mentions of phishing may trigger a phishing-family check while recording that evidence of an observed lure, attachment, or link is still missing. Such hypotheses will be passed to guide retrieval.

4.4 Evidence-Aligned Retrieval and Technique Mapping

This module uses the shared concept representation to connect extracted observations with candidate techniques.

Step 1: retrieve compatible profiles. Retrieval targets are constructed from the evidence units, local groups, and marked hypotheses produced in Section 4.3. For each target $z \in Z_s$, candidate generation is defined as

$$Q_z = \text{Expand}\big(\text{TopK}_{t \in \mathcal{T}} \text{Match}(\Phi(z), P_t)\big), \tag{3}$$

where Match ranks technique profiles by concept compatibility, TopK selects up to K highest-ranked profiles per target as initial candidates, and Expand retains additional techniques indicated by behavioral rules and uses R_t to add relevant parents, siblings, and known confusers. For marked hypotheses, $\Phi(z)$ encodes concepts that guide retrieval without constituting observed evidence.

Matching compares $\Phi(z)$ with the profile concepts Φ_t, using salient phrases and aliases in S_t as additional signals. Specific mechanism matches receive greater priority than broad lexical overlap, with goals, actions, and objects providing complementary support. Evidential status also affects ranking, giving contextual material less weight than observed behavior.

Step 2: construct the comparison context. Entries for the same technique are merged under its canonical identifier. The merged entry records which concepts matched, which evidence is linked to it, how it was retrieved, and what evidence is missing. An added parent profile without a structural match remains an alternative and does not inherit its child's support. The resulting candidate packet allows the mapper to compare retrieved techniques and

nearby alternatives against the same evidence. For example, a Run-key observation may retrieve both startup persistence and registry modification. The key's startup role and referenced executable provide evidence for distinguishing the behaviors.

Step 3: evaluate technique claims. The mapping LLM receives a bounded packet containing source-linked evidence units and groups, candidate techniques, nearby alternatives, and acceptance conditions derived from Q_t. A selected subset of candidates forms the mandatory decision queue. For each candidate in the mandatory decision queue, it returns *accept*, *abstain*, or *reject*, together with supporting evidence identifiers and structured proof gaps. The remaining candidates provide alternatives for comparison. If none of the candidates fit, the model may propose another technique supported by observed report evidence. Such proposals must resolve to an indexed profile and satisfy the same evidence checks.

4.5 Output Control

MEvince checks whether extracted observations can be traced back to the report and whether proposed technique assignments have sufficient support in the report. The two controls operate after extraction and mapping, respectively, so LLM responses are not treated as final decisions.

Evidence-unit control. An evidence unit records a behavioral statement from the report, its source spans, and its evidential status. In the Reaver example below, `U5` records XOR decryption of an embedded file as *observed*: the report describes the behavior as having occurred. After extraction, the control normalizes these records, aligns quoted spans with the source segment, and records offsets for matched text. It assigns local identifiers to units and literals, and recovers selected artifacts, such as commands and registry paths, directly from the report. Subsequent stages use these identifiers within the corresponding report and segment to retrieve the original passages.

Claim verification. A technique claim contains a candidate technique, a verdict, and evidence references. The verifier resolves these references and checks the claim against the report evidence and requirements Q_t. Acceptance requires observed behavior concerning the malware under analysis or explicit capability evidence permitted by a matching rule; background, advisory text, and hypotheses alone are insufficient. An *accept* claim without valid citations becomes *abstain*, where a *proof gap* records missing or conflicting evidence and marks a *blocking* reason. In the example below, the accepted T1140 claim cites `U5/G3`, whereas the mapper rejects T1057 with a blocking `no_observed_support` gap because the source segment contains no process-discovery behavior.

Reaver: evidence and mapper decisions

`U5` (*observed*): XOR decryption of an embedded file.

`T1140`	*accept*	File decryption; cites `U5/G3`.
`T1057`	*reject*	No process discovery in this segment. Gap: `no_observed_support` (*blocking*).

An *abstain* claim may be accepted only after passing the same checks and a further assessment of its evidence support. The evidence must match the candidate profile through a mechanism, a salient phrase, or all three action–object–goal dimensions. The assessment considers whether the support is observed, how specifically it matches the candidate, retrieval strength, and the number of distinct supporting units and groups. Claims are then consolidated across segments, with supported sub-techniques taking precedence over redundant parents; each decision retains its verdict, claim and evidence references, proof gaps, and verification results.

4.6 Offline Adaptation of the Retrieval Interface

MEvince optionally uses labeled training reports to adjust which retrieved techniques the LLM must explicitly judge. For each technique annotated in a training report, MEvince retains up to two evidence units that describe observed behavior, are relevant to mapping, and align with that technique's profile. These examples form a positive evidence memory; missing annotations are not negatives because report labels may omit behaviors.

Memory can move an alternative already in the retrieved packet into the mandatory decision queue, replacing its weakest-scoring member while keeping the base concept vocabulary unchanged. For each candidate, we compare its evidence texts with stored examples of the same technique. The highest cosine similarity between their embeddings gives the candidate's score. Eligibility requires observed support or capability support permitted by retrieval rules, and the technique must have examples from a minimum number of training reports. Eligible alternatives are considered in descending score order and must reach the threshold and score no lower than the replaced candidate. Exchanges are capped per packet; queue size remains unchanged. Taking Figure 3 as an example, the Reaver report describes placing a shortcut in a startup path, and T1547.009 (Shortcut Modification), initially a confuser, enters the queue through similar training examples.

5 Evaluation

We evaluate MEvince on overall technique identification (**RQ1**), evidence selection and concept-based retrieval (**RQ2**), output control (**RQ3**), optional evidence-memory adaptation (**RQ4**), and online LLM workload (**RQ5**).

5.1 Experimental Setup

Dataset. Our benchmark comprises 610 public malware-analysis reports referenced by the MITRE ATT&CK Enterprise software knowledge base [42], with 6,095 report–technique assignments. We reserve 555 reports for optional in-domain adaptation (5,592 assignments) and use the remaining 55 for development evaluation (503 assignments across 164 technique identifiers). All main comparisons, including the evidence-memory comparison, use the same 55 evaluation reports. The partitions are report-disjoint but not software-disjoint: reports in different partitions may describe the same software entry. Gold labels are derived from software–technique relationships citing report URLs.

Baselines. We compare 11 baselines spanning four families: document classification with RoBERTa [31] and CySecBERT [2]; mention extraction and structured mapping with NER variants and AttacKG [28]; supervised fine-tuning of Llama and Qwen [16, 34]; and context-driven LLM methods, including Direct Prompt, RAG, and CTIKG [10, 18, 20]. The GPT-based baselines and MEvince use GPT-4o. Methods retain their implementation-specific prompts and decoding schedules; all predictions are normalized by the same evaluator. More details are provided in Appendix C.1.

Table 2: Technique identification performance.

Method		Exact ATT&CK IDs				Parent IDs			
Type	**Name**	**F1**	**Recall**	**Prec.**	**Jacc.**	**F1**	**Recall**	**Prec.**	**Jacc.**
Classifier	RoBERTa	0.250	0.234	0.294	0.158	0.351	0.369	0.389	0.233
	CySecBERT	0.140	0.214	0.111	0.079	0.295	0.503	0.225	0.183
Extraction	NER-base	0.105	0.166	0.091	0.059	0.151	0.212	0.139	0.089
	NER-full	0.144	0.268	0.108	0.082	0.214	0.347	0.172	0.127
	AttacKG	0.038	0.069	0.028	0.020	0.099	0.180	0.072	0.055
SFT	Llama-3.1-8B	0.244	0.221	0.303	0.154	0.350	0.357	0.404	0.232
	Llama-3.1-70B	0.264	0.235	0.329	0.169	0.379	0.379	0.438	0.256
	Qwen2.5-14B	0.255	0.245	0.288	0.161	0.363	0.395	0.385	0.241
Inference	Direct Prompt	0.189	0.194	0.205	0.112	0.271	0.286	0.286	0.169
	RAG	0.251	**0.424**	0.191	0.149	0.336	**0.529**	0.270	0.211
	CTIKG	0.164	0.167	0.174	0.097	0.262	0.294	0.267	0.161
Ours	**MEvince**	**0.310**	0.302	**0.384**	**0.200**	**0.386**	0.383	**0.463**	**0.260**

Evaluation protocol. Our main comparison evaluates MEvince against the 11 baselines (Table 2). We separately evaluate optional evidence-memory adaptation alongside baselines adapted on our training partition (Table 4). Some baselines in the main comparison use models trained on data from their original implementations. The evidence memory is constructed from training reports only; its configuration is selected through training-only validation, and both are fixed before evaluation.

We report report-level macro precision, recall, F1, and Jaccard at exact-ID and parent-technique granularity, with macro F1 as the primary metric. Exact-ID evaluation preserves technique and sub-technique identifiers, whereas parent-level evaluation maps sub-techniques to their parent identifiers. Component analyses also report aggregate error counts and micro F1.

Implementation. The knowledge base contains 651 technique and sub-technique profiles from ATT&CK Enterprise v19.2. For each evidence target, retrieval selects up to four initial profiles and supplements them with techniques indicated by behavioral rules and ontology-based alternatives. MEvince uses GPT-4o with temperature 1.0 and a 2,048-token output limit. Evidence-memory configuration details are provided in Appendix C.

5.2 Overall Technique Identification (RQ1)

Table 2 shows that MEvince achieves the highest macro F1 and Jaccard at both granularities. Its exact-ID F1 reaches 0.310, exceeding the strongest baseline, Llama-3.1-70B (0.264), by 17.4%. At the parent level, its F1 is 0.386, compared with 0.379 for the strongest baseline. The advantage is more pronounced at the exact-ID level, where evaluation requires preserving distinctions between techniques and sub-techniques.

Among the context-driven LLM methods, RAG improves on Direct Prompt, suggesting the value of external technique knowledge. However, neither RAG nor CTIKG matches MEvince despite using the same LLM backbone. These results suggest that access to external knowledge alone is insufficient for reliable technique identification; how that knowledge is connected to report observations and how proposed assignments are verified also matter. Against RAG, a paired report bootstrap [9] gives MEvince an exact-ID macro-F1 advantage of 0.060, with a 95% percentile interval of $[0.014, 0.106]$. The precision–recall pattern provides further insight.

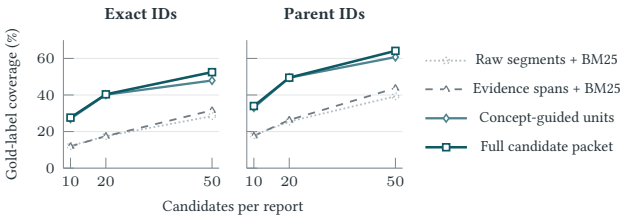

Figure 2: Candidate coverage at different retrieval budgets.

RAG achieves the highest exact-ID recall (0.424), but its precision is only 0.191. In contrast, MEvince approximately doubles precision to 0.384 while retaining the second-highest recall (0.302). At the parent level, the same trade-off holds: MEvince achieves 0.463 precision and 0.383 recall, compared with 0.270 and 0.529 for RAG. These results are consistent with the separation of retrieval and verification in MEvince: retrieved techniques remain hypotheses until supported by report evidence. Further discussion of this tradeoff and the study's limitations is provided in Appendix A.

5.3 Extraction and Retrieval Ablation (RQ2)

To separate evidence selection from concept-based matching, we compare four retrieval variants using the same archived reports and 651 technique profiles, with candidate budgets of 10, 20, and 50 per report. Candidates are deduplicated and ranked at the report level before applying each budget. Gold-label coverage measures the fraction of reference report–technique associations retrieved across reports.

Evidence extraction. *Raw segments + BM25* [38] retrieves directly from report segments, whereas *Evidence spans + BM25* uses the text of extracted observed evidence units as queries while keeping the retriever fixed. At a budget of 50, exact-ID coverage increases from 28.4% to 31.6%, and parent-level coverage from 39.3% to 43.7% (Figure 2). At smaller budgets, the two BM25 variants achieve similar coverage. Evidence selection therefore provides a modest retrieval benefit, most evident at the larger candidate budget.

Concept-based retrieval. For *Concept-guided units*, we select primary candidates from the merged retrieval packets, keeping those linked to evidence units and supported by observed behavior. We

Table 3: Effect of document-level output control.

Decision stage	Exact ATT&CK IDs F1	Recall	Prec.	Jacc.
Mapping accepts only	0.306	**0.308**	0.366	0.194
+ document verifier	**0.310**	0.302	**0.384**	**0.200**
	Parent IDs			
Mapping accepts only	0.383	**0.384**	0.458	0.256
+ document verifier	**0.386**	0.383	**0.463**	**0.260**

rank this subset using their merged retrieval scores. At a budget of 50, this subset achieves 47.9% exact-ID coverage and 60.7% parent-level coverage. The *Full candidate packet* additionally uses local evidence groups and ontology-based alternatives, increasing coverage to 52.5% and 64.1%. Both concept-based variants outperform the lexical retrievers at all three budgets and both granularities. These results indicate that concept-based retrieval yields a larger coverage gain than evidence selection alone. Additional retrieval-depth results are reported in Appendix C.2.

5.4 Output Control Ablation (RQ3)

Effect of claim verification. Table 3 compares deduplicated claims accepted by the mapping LLM with the final decisions after document-level verification. Both settings use identical evidence, candidates, and mapping responses, isolating the effect of verification. The verifier yields 25 fewer exact-ID false positives and three fewer true positives, increasing macro precision from 0.366 to 0.384 and F1 from 0.306 to 0.310. Parent-level F1 also increases, from 0.383 to 0.386. Verification thus improves precision at the cost of a small reduction in recall, yielding a modest F1 gain.

Evidence behind decisions. In the Medusa case, the mapper accepts T1048 (Exfiltration Over Alternative Protocol) although the cited data-theft statement does not specify a transfer protocol. The verifier rejects the assignment because the candidate was retrieved only as a low-scoring alternative with no matched profile concepts. This removes one exact-ID false positive without changing the evidence or mapping response; the full comparison is shown in Figure 4 in Appendix C.4. We also report the corpus-wide structural audit in Appendix C.3 and discuss potential analyst workflows using these records in Appendix D.

5.5 Evidence-Memory Adaptation (RQ4)

We evaluate optional evidence-memory adaptation on the same 55 reports used in RQ1. Table 4 compares this variant against classifiers and LLM baselines adapted using the training partition. Without updating model parameters, MEvince with memory achieves exact-ID and parent-level macro F1 scores of 0.316 and 0.394, compared with 0.292 and 0.385 for the strongest adapted baseline.

We apply the evidence-memory revision described in Section 4.6. For paired evaluation, we rerun mapping for revised packets, retain new claims only for promoted and demoted techniques, and reuse archived claims for all other techniques. Memory revision modifies 66 packets without increasing their decision budgets and increases the number of gold report–technique associations included in the decision queues from 264 to 271. Final predictions show a net gain

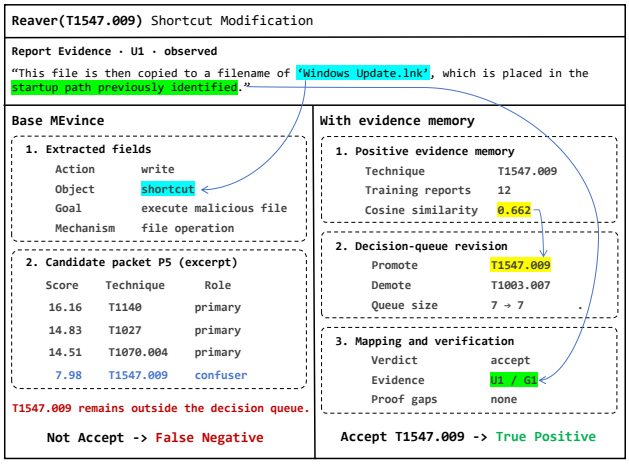

Figure 3: Evidence-memory revision for T1547.009.

of seven exact-ID true positives, with macro F1 rising from 0.310 to 0.316. Parent-level macro F1 likewise increases from 0.386 to 0.394.

Figure 3 illustrates this mechanism in the Reaver report. The report describes malware creating a shortcut and placing it in a previously identified startup path. MEvince initially retrieves T1547.009 as a confuser but leaves it outside the mandatory decision queue. Evidence prototypes from 12 training reports promote it into the queue by replacing one incumbent, keeping the queue at seven candidates. The resulting acceptance cites U1 and G1 from the current report and has no proof gap. At the report level, adaptation recovers T1547.009 and T1012 without adding a false positive.

5.6 LLM Workload (RQ5)

We compare the online LLM workload of Direct Prompt, RAG, CTIKG, and MEvince on the shortest, median-length, and longest reports among the 55 evaluation reports, selected by character length. All four methods use GPT-4o. Table 5 reports generation calls and total token usage recorded by the API, excluding embedding queries and offline preparation. Direct Prompt uses one generation call per report and has the lowest token consumption. MEvince uses more tokens than RAG, as it runs separate LLM stages for evidence extraction and technique mapping. Compared with CTIKG, it requires fewer calls and reduces generation-token usage by 62.1–83.8%. Input/output breakdowns are provided in Table 7. Across the evaluation set, estimated generation-token usage for MEvince averages 49.9K per report, with a median of 41.8K.

6 Conclusion

We presented MEvince, a knowledge-constrained LLM reasoning framework for report-level malware technique identification. The framework aligns dispersed report observations with ATT&CK technique definitions through a shared behavioral representation, while maintaining a clear distinction among source evidence, interpretive knowledge, and unverified hypotheses. Evaluations against 11 baselines on public malware reports demonstrate that MEvince improves fine-grained technique identification, while an offline evidence memory enables further gains by refining bounded candidate

Table 4: Technique identification performance with in-domain adaptation.

Method		Exact ATT&CK IDs				Parent IDs			
Type	**Name**	**F1**	**Recall**	**Prec.**	**Jacc.**	**F1**	**Recall**	**Prec.**	**Jacc.**
Classifier	RoBERTa	0.285	0.271	0.328	0.183	0.358	0.365	0.391	0.237
	CySecBERT	0.199	0.187	0.242	0.119	0.306	0.313	0.343	0.195
SFT	Llama-3.1-8B	0.260	0.294	0.263	0.161	0.360	0.400	0.366	0.238
	Llama-3.1-70B	0.292	**0.337**	0.296	0.187	0.385	**0.444**	0.389	0.260
	Qwen2.5-14B	0.291	0.331	0.293	0.184	0.368	0.429	0.366	0.241
Ours	**MEvince + memory**	**0.316**	0.317	**0.379**	**0.205**	**0.394**	0.396	**0.465**	**0.269**

Table 5: Online LLM workload across report lengths.

	Shortest		Median		Longest	
Method	**Calls**	**Tokens (K)**	**Calls**	**Tokens (K)**	**Calls**	**Tokens (K)**
Direct Prompt	1	0.97	1	3.55	1	10.11
RAG	4	4.25	24	25.26	72	79.01
CTIKG	39	35.01	249	254.30	794	791.34
MEvince	6	13.28	12	41.29	45	144.11

Report lengths of the three settings are 2,059, 11,238, and 34,870 characters, respectively.

queues without updating model parameters. Further analyses show that the framework improves candidate coverage while reducing false-positive assignments, and provenance audits confirm that accepted assignments remain traceable to source evidence.

References

[1] Gbadebo Ayoade, Swarup Chandra, Latifur Khan, Kevin Hamlen, and Bhavani Thuraisingham. 2018. Automated threat report classification over multi-source data. In *2018 IEEE 4th International Conference on Collaboration and Internet Computing (CIC)*. IEEE, 236–245.

[2] Markus Bayer, Philipp Kuehn, Ramin Shanehsaz, and Christian Reuter. 2024. Cysecbert: A domain-adapted language model for the cybersecurity domain. *ACM Transactions on Privacy and Security* 27, 2 (2024), 1–20.

[3] Marvin Büchel, Tommaso Paladini, Stefano Longari, Michele Carminati, Stefano Zanero, Hodaya Binyamini, Gal Engelberg, Dan Klein, Giancarlo Guizzardi, Marco Caselli, et al. 2025. SoK: Automated TTP Extraction from CTI Reports–Are We There Yet?. In *34th USENIX security symposium (USENIX Security 25)*. 4621–4641.

[4] Feng Chen, Jiajia Liu, Kaixiang Ji, Wang Ren, Jian Wang, and Jingdong Chen. 2023. Learning implicit entity-object relations by bidirectional generative alignment for multimodal ner. In *Proceedings of the 31st ACM international conference on multimedia*. 4555–4563.

[5] Minghao Chen, Kaijie Zhu, Bin Lu, Ding Li, Qingjun Yuan, and Yuefei Zhu. 2025. AECR: Automatic attack technique intelligence extraction based on fine-tuned large language model. *Computers & Security* 150 (2025), 104213.

[6] Yutong Cheng, Osama Bajaber, Saimon Amanuel Tsegai, Dawn Song, and Peng Gao. 2024. CTINEXUS: leveraging optimized LLM in-context learning for constructing cybersecurity knowledge graphs under data scarcity. *arXiv preprint arXiv:2410.21060* (2024).

[7] Jacob Devlin, Ming-Wei Chang, Kenton Lee, and Kristina Toutanova. 2019. BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding. In *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies, Volume 1 (Long and Short Papers)*. Association for Computational Linguistics, 4171–4186. https://doi.org/10.18653/v1/N19-1423

[8] Matthijs Douze, Alexandr Guzhva, Chengqi Deng, Jeff Johnson, Gergely Szilvasy, Pierre-Emmanuel Mazaré, Maria Lomeli, Lucas Hosseini, and Hervé Jégou. 2024. The Faiss library. *arXiv preprint arXiv:2401.08281* (2024). https://arxiv.org/abs/2401.08281

[9] B. Efron. 1979. Bootstrap Methods: Another Look at the Jackknife. *The Annals of Statistics* 7, 1 (1979), 1–26. https://doi.org/10.1214/aos/1176344552

[10] Reza Fayyazi, Rozhina Taghdimi, and Shanchieh Jay Yang. 2024. Advancing TTP analysis: Harnessing the power of large language models with retrieval augmented generation. In *2024 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 255–261.

[11] Romy Fieblinger, Md Tanvirul Alam, and Nidhi Rastogi. 2024. Actionable cyber threat intelligence using knowledge graphs and large language models. In *2024 IEEE European symposium on security and privacy workshops (EuroS&PW)*. IEEE, 100–111.

[12] Keisuke Furumoto, Tomohiro Morikawa, Antti Kolehmainen, Bilhanan Silverajan, Takeshi Takahashi, and Daisuke Inoue. 2025. A Comprehensive Survey of Threat Intelligence Research: A Measurement-Based Study. *Comput. Surveys* 58, 6, Article 153 (Dec. 2025), 35 pages. https://doi.org/10.1145/3772280

[13] Luyu Gao, Zhuyun Dai, Panupong Pasupat, Anthony Chen, Arun Tejasvi Chaganty, Yicheng Fan, Vincent Zhao, Ni Lao, Hongrae Lee, Da-Cheng Juan, and Kelvin Guu. 2023. RARR: Researching and Revising What Language Models Say, Using Language Models. In *Proceedings of the 61st Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*. Association for Computational Linguistics, 16477–16508. https://doi.org/10.18653/v1/2023.acl-long.910

[14] Peng Gao, Fei Shao, Xiaoyuan Liu, Xusheng Xiao, Zheng Qin, Fengyuan Xu, Prateek Mittal, Sanjeev R. Kulkarni, and Dawn Song. 2021. Enabling Efficient Cyber Threat Hunting With Cyber Threat Intelligence. In *2021 IEEE 37th International Conference on Data Engineering (ICDE)*. IEEE, 193–204. https://doi.org/10.1109/ICDE51399.2021.00024

[15] Tianyu Gao, Howard Yen, Jiatong Yu, and Danqi Chen. 2023. Enabling Large Language Models to Generate Text with Citations. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*. Association for Computational Linguistics, 6465–6488. https://doi.org/10.18653/v1/2023.emnlp-main.398

[16] Aaron Grattafiori, Abhimanyu Dubey, Abhinav Jauhri, Abhinav Pandey, Abhishek Kadian, Ahmad Al-Dahle, Aiesha Letman, Akhil Mathur, Alan Schelten, Alex Vaughan, et al. 2024. The llama 3 herd of models. *arXiv preprint arXiv:2407.21783* (2024).

[17] Wenbo Guo, Chengwei Liu, Limin Wang, Yiran Zhang, Jiahui Wu, Zhengzi Xu, and Yang Liu. 2026. IntelliRadar: A Comprehensive Platform to Pinpoint Malicious Package Information from Cyber Intelligence. In *2026 IEEE/ACM 48th International Conference on Software Engineering (ICSE)*. IEEE Computer Society.

[18] Kyla Guru, Robert J Moss, and Mykel J Kochenderfer. 2025. On Technique Identification and Threat-Actor Attribution using LLMs and Embedding Models. In *2025 International Conference on Cybersecurity and AI-Based Systems (Cyber-AI)*. IEEE, 332–339.

[19] Yiling He, Junchi Lei, Zhan Qin, Kui Ren, and Chun Chen. 2025. Combating concept drift with explanatory detection and adaptation for android malware classification. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*. 978–992.

[20] Liangyi Huang and Xusheng Xiao. 2024. CTIKG: LLM-Powered Knowledge Graph Construction from Cyber Threat Intelligence. In *Proceedings of the First Conference on Language Modeling (COLM 2024)* (Philadelphia, PA, USA).

[21] Ghaith Husari, Ehab Al-Shaer, Mohiuddin Ahmed, Bill Chu, and Xi Niu. 2017. TTPDrill: Automatic and accurate extraction of threat actions from unstructured text of cti sources. In *Proceedings of the 33rd annual computer security applications conference*. 103–115.

[22] Ghaith Husari, Xi Niu, Bill Chu, and Ehab Al-Shaer. 2018. Using entropy and mutual information to extract threat actions from cyber threat intelligence. In *2018 IEEE international conference on intelligence and security informatics (ISI)*. IEEE, 1–6.

[23] Youngjin Jin, Eugene Jang, Jian Cui, Jin-Woo Chung, Yongjae Lee, and Seungwon Shin. 2023. Darkbert: A language model for the dark side of the internet. In *Proceedings of the 61st annual meeting of the association for computational linguistics (volume 1: long papers)*. 7515–7533.

[24] Damjan Kalajdzievski. 2023. A Rank Stabilization Scaling Factor for Fine-Tuning with LoRA. *arXiv preprint arXiv:2312.03732* (2023). https://arxiv.org/abs/2312.03732

[25] Valentine Legoy, Marco Caselli, Christin Seifert, and Andreas Peter. 2020. Automated retrieval of att&ck tactics and techniques for cyber threat reports. *arXiv preprint arXiv:2004.14322* (2020).

[26] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. 2020. Retrieval-Augmented Generation for

Knowledge-Intensive NLP Tasks. In *Advances in Neural Information Processing Systems*, Vol. 33. Curran Associates, Inc., 9459–9474. https://proceedings.neurips.cc/paper/2020/hash/6b493230205f780e1bc26945df7481e5-Abstract.html
[27] Jing Li, Aixin Sun, Jianglei Han, and Chenliang Li. 2022. A survey on deep learning for named entity recognition. *IEEE transactions on knowledge and data engineering* 34, 1 (2022), 50–70.
[28] Zhenyuan Li, Jun Zeng, Yan Chen, and Zhenkai Liang. 2022. AttacKG: Constructing technique knowledge graph from cyber threat intelligence reports. In *European symposium on research in computer security*. Springer, 589–609.
[29] Xiaojing Liao, Kan Yuan, XiaoFeng Wang, Zhou Li, Luyi Xing, and Raheem Beyah. 2016. Acing the ioc game: Toward automatic discovery and analysis of open-source cyber threat intelligence. In *Proceedings of the 2016 ACM SIGSAC conference on computer and communications security*. 755–766.
[30] Chenjing Liu, Junfeng Wang, and Xiangru Chen. 2022. Threat intelligence ATT&CK extraction based on the attention transformer hierarchical recurrent neural network. *Applied Soft Computing* 122 (2022), 108826.
[31] Yinhan Liu, Myle Ott, Naman Goyal, Jingfei Du, Mandar Joshi, Danqi Chen, Omer Levy, Mike Lewis, Luke Zettlemoyer, and Veselin Stoyanov. 2019. RoBERTa: A Robustly Optimized BERT Pretraining Approach. *arXiv preprint arXiv:1907.11692* (2019). https://arxiv.org/abs/1907.11692
[32] Carl Maverick Pascual, Michael Jhon Ofiaza, and Patrick Angelo Roderno. 2018. AutoIt-Compiled Worm Sends Fileless BLADABINDI/njRAT. https://www.trendmicro.com/en_us/research/18/k/autoit-compiled-worm-affecting-removable-media-delivers-fileless-version-of-bladabindi-njrat-backdoor.html. Trend Micro Research, accessed March 31, 2026.
[33] Sujan Perera, Pablo Mendes, Amit Sheth, Krishnaprasad Thirunarayan, Adarsh Alex, Christopher Heid, and Greg Mott. 2015. Implicit entity recognition in clinical documents. In *Proceedings of the Fourth Joint Conference on Lexical and Computational Semantics*. 228–238.
[34] Qwen, An Yang, Baosong Yang, Beichen Zhang, Binyuan Hui, Bo Zheng, Bowen Yu, Chengyuan Li, Dayiheng Liu, Fei Huang, et al. 2025. Qwen2.5 Technical Report. *arXiv preprint arXiv:2412.15115* (2025). https://arxiv.org/abs/2412.15115
[35] Fariha Ishrat Rahman, Sadaf Md Halim, Anoop Singhal, and Latifur Khan. 2024. Alert: A framework for efficient extraction of attack techniques from cyber threat intelligence reports using active learning. In *IFIP Annual Conference on Data and Applications Security and Privacy*. Springer, 203–220.
[36] Priyanka Ranade, Aritran Piplai, Anupam Joshi, and Tim Finin. 2021. Cybert: Contextualized embeddings for the cybersecurity domain. In *2021 IEEE international conference on big data (Big Data)*. IEEE, 3334–3342.
[37] Nanda Rani, Bikash Saha, Vikas Maurya, and Sandeep Kumar Shukla. 2024. TTPXHunter: Actionable threat intelligence extraction as ttps from finished cyber threat reports. *Digital Threats: Research and Practice* 5, 4 (2024), 1–19.
[38] Stephen Robertson and Hugo Zaragoza. 2009. The Probabilistic Relevance Framework: BM25 and Beyond. *Foundations and Trends in Information Retrieval* 3, 4 (2009), 333–389. https://doi.org/10.1561/1500000019
[39] James Ross and Jackie Lasky. 2023. Our TRAM Large Language Model Automates TTP Identification in CTI Reports. https://medium.com/mitre-engenuity/our-tram-large-language-model-automates-ttp-identification-in-cti-reports-5bc0a30d4567. MITRE Engenuity Center for Threat-Informed Defense, published August 29, 2023; accessed March 31, 2026.
[40] Kiavash Satvat, Rigel Gjomemo, and VN Venkatakrishnan. 2021. Extractor: Extracting attack behavior from threat reports. *arXiv preprint arXiv:2104.08618* (2021).
[41] Yashovardhan Sharma, Eleonora Giunchiglia, Simon Birnbach, and Ivan Martinovic. 2023. To ttp or not to ttp?: Exploiting ttps to improve ml-based malware detection. In *2023 IEEE International Conference on Cyber Security and Resilience (CSR)*. IEEE, 8–15.
[42] The MITRE Corporation. [n.d.]. ATT&CK Matrix for Enterprise. https://attack.mitre.org. Accessed: 2026-03-29.
[43] Zhou Xuan, Xiangzhe Xu, Mingwei Zheng, Louis Zheng-Hua Tan, Jinyao Guo, Tiantai Zhang, Le Yu, Chengpeng Wang, and Xiangyu Zhang. 2026. Identifying Adversary Tactics and Techniques in Malware Binaries with an LLM Agent. *arXiv preprint arXiv:2602.06325* (2026).
[44] An Yang, Baosong Yang, Binyuan Hui, Bo Zheng, Bowen Yu, Chang Zhou, Chengpeng Li, Chengyuan Li, Dayiheng Liu, Fei Huang, et al. 2024. Qwen2 Technical Report. *arXiv preprint arXiv:2407.10671* (2024). https://arxiv.org/abs/2407.10671
[45] Huixia Zhang, Guowei Shen, Chun Guo, Yunhe Cui, and Chaohui Jiang. 2021. EXAction: Automatically Extracting Threat Actions from Cyber Threat Intelligence Report Based on Multimodal Learning. *Security and Communication Networks* 2021, 1 (2021), 5586335.

A Supplementary Discussion

Evidence Control and the Precision–Recall Tradeoff. RAG attains high recall but produces many assignments that do not match the benchmark associations; MEvince instead exposes uncertain claims as abstentions. The retrieval ablation shows that most of the candidate-coverage improvement comes from comparing evidence and profiles in the shared concept space, with a smaller additional gain from evidence extraction. At the decision stage, document-level verification provides a modest precision gain on identical mapping responses. The evidence-memory experiment shows that positive training examples can improve candidate selection before mapping. The memory improves recall on the 55 evaluation reports while retaining the same mapping and verification procedures. In multi-label mapping, every weak assignment added for recall becomes another claim to verify before it can safely enter a knowledge base or detection workflow. Retrieval should preserve plausible coverage, while acceptance remains conservative about what the report supports; abstention keeps a candidate for review without presenting it as observed behavior.

Traceability and Analyst Interaction. Accepted and abstained claims link through evidence units and groups to source spans. Candidate packets retain matched concepts and confusable alternatives, while claim records retain evidence references and proof gaps. These records help an analyst distinguish extraction errors, retrieval mismatches, and unsupported decisions. The claim score summarizes how well the evidence satisfies the verification rules. It is not a calibrated probability; consequential use still requires human review.

Limitations. The development split informed method design. A larger independent evaluation, especially on unseen software families, is needed. Moreover, ATT&CK labels are scoped to cited software–report associations rather than exhaustive behavior annotations. Label disagreement therefore does not by itself establish an unsupported claim. Our provenance checks establish that citations resolve to report spans, not that an expert would judge each span sufficient for its technique; evaluating that judgment and analyst utility remains future work.

B Concept Inventory and Semantic Composition

Table 6 summarizes the inventory used in our experiments, with representative entries for each component. The four concept dimensions contain 450 canonical behavioral labels. Each label has a definition and lexical or structural anchors; these primitives describe behavior rather than assign technique identifiers. The semantic layer contains 34 role templates and 17 coupling motifs. A role template combines primitives to describe a behavior, such as registry persistence. A coupling motif links behaviors described in nearby observations, such as delivery followed by execution.

C Reproducibility Details

MEvince uses the ATT&CK Enterprise v19.2 bundle and the `gpt-4o` alias with temperature 1.0 and a 2,048-token output limit. Base profiles use ATT&CK technique IDs, names, and descriptions, not software–technique usage records. Baselines retain their method-specific prompts and decoding schedules. All reported metrics are computed from per-report predictions using the common evaluator.

Evidence-memory configuration. The memory contains 9,440 positive prototypes from the 555-report training partition. For each technique annotated in a training report, we select evidence units

Table 6: Concept inventory used by MEvince.

Component	Count	Role	Representative entries
Action	36	What the threat does; preserves the behavioral predicate.	execute; modify; query; inject; connect
Object	94	What the action affects; identifies the artifact or resource.	process; file; registry key; credential; network configuration
Goal	18	Why the behavior is performed; separates similar operations with different purposes.	persistence; discovery; credential access; command and control
Mechanism	302	How the behavior is carried out; captures technique-specific means.	Run-key startup; PowerShell; process hollowing; non-standard port
Role template	34	Combines concepts that describe the same behavior.	registry persistence; fileless execution; discovery; C2; exfiltration
Coupling motif	17	Connects related behaviors described in nearby evidence units.	delivery–execution; Run-key–fileless execution; C2–exfiltration

that describe observed behavior and are relevant to mapping. We rank these units by their TF–IDF alignment with the technique profile and retain at most two with scores of at least 0.01. Evidence texts and prototypes are encoded with `text-embedding-3-small` at 512 dimensions. Configuration selection uses five-fold validation grouped by software identifier, with prototypes from each held-out fold excluded. On held-out training reports, we measure how many gold candidates each pre-specified configuration adds to or removes from the base queue. We select the configuration with the largest net gain per revised packet. The selected setting uses a cosine threshold of 0.65, requires prototypes from at least five training reports per eligible technique, and permits at most two exchanges per packet. The memory and configuration are fixed before evaluation.

Archived outputs and paired evaluation. Each report retains separate JSON outputs for extraction, concept mining, retrieval, mapping, and final decisions. These records preserve evidence units and groups, candidate packets, mapping responses, and decision references. For evidence-memory evaluation, we rerun mapping for revised packets, retain new claims only for promoted and demoted techniques, and reuse archived claims for all other techniques. Both variants use the same extraction results and document-level verifier.

Component comparisons. Retrieval coverage is evaluated on the same report inputs and technique profiles, using the same report-level candidate budgets for all variants. The output-control comparison holds evidence, candidates, and mapping responses fixed, changing only document-level verification.

Workload accounting. The comparison in Section 5.6 uses API-recorded input and output tokens from separate replays on reports 2, 323, and 705, the shortest, median-length, and longest reports by character count in the 55-report evaluation set. Table 7 provides the input/output breakdown. Generation calls are counted separately from embedding queries, and offline preparation is excluded. RAG uses 4, 24, and 72 embedding queries on these reports, corresponding to 404, 2,454, and 8,751 input-token equivalents, respectively. For the 55-report estimates, extraction and mapping prompts are reconstructed from recorded inputs using the original prompt templates, and parsed responses are serialized consistently before tokenization. Replay outputs are not used to compute identification accuracy.

Table 7: Input and output token usage.

	Shortest		Median		Longest	
Method	**Input**	**Output**	**Input**	**Output**	**Input**	**Output**
Direct Prompt	0.65	0.32	2.91	0.64	9.18	0.93
RAG	3.81	0.44	22.92	2.34	70.90	8.11
CTIKG	28.54	6.47	206.02	48.28	648.18	143.16
MEvince	9.62	3.66	28.49	12.81	99.25	44.86

Values are in thousands of generation tokens, rounded independently. The reports are the same as those in Table 5.

C.1 Baseline Descriptions and Adaptation

Classification. RoBERTa and CySecBERT provide encoder-based classification baselines. RoBERTa uses general-purpose language representations, whereas CySecBERT incorporates continued pretraining on cybersecurity text [2]. Their report-level technique predictions are evaluated using the common evaluator.

NLP-based extraction and mapping. We follow the NER pipeline designs studied by Büchel et al. [3]. NER-base performs exact matching; NER-full additionally uses part-of-speech tagging, lemmatization, related-word detection, and parsing to recognize explicit references despite lexical and syntactic variation. These pipelines do not require labeled task-specific training data. AttacKG [28] extracts attack-relevant entities and dependencies, constructs behavior graphs, and identifies techniques by aligning these graphs with technique templates. We retain the technique identifiers returned by each pipeline, including parent-level predictions.

Supervised fine-tuning. The SFT baselines use 8B and 70B Llama instruction models and a 14B Qwen instruction model. Sentence-level training converts labeled text into chat-formatted examples asking the model to identify techniques expressed in each sentence. We use Unsloth with rank-stabilized LoRA [24], rank 64, an alpha of 16, and zero adapter dropout. Adapters target attention and feed-forward projections, token embeddings, and the output head. The shared recipe uses three epochs, a per-device batch size of two, and two gradient-accumulation steps; the backbone and learning rate vary by configuration. At inference, each sentence is processed with greedy decoding and at most 256 new tokens. Technique identifiers are extracted from the responses and deduplicated across sentences to obtain report-level predictions.

Context-driven LLM methods. Direct Prompt, RAG, and CTIKG use GPT-4o for inference. Direct Prompt supplies the complete report and requests technique identifiers with supporting report quotes, without external retrieval. Our RAG implementation combines BM25 and FAISS-based dense retrieval [8] with weights of 0.3 and 0.7, respectively, using `text-embedding-3-large`. It indexes

non-deprecated, Windows-relevant Enterprise technique documentation. For each report segment, the LLM receives up to ten deduplicated technique descriptions, each truncated to 240 characters, and identifies techniques supported by that segment. Predictions are combined across segments. Our CTIKG implementation [20] performs repeated triple extraction, consolidates entities and relations into report-level memory, and maps the resulting representation to technique identifiers.

Adaptation and evaluation. Table 2 uses baseline configurations without additional fitting on our 555-report training partition; some underlying models have been trained on other data. Table 4 separately evaluates classifiers and SFT models adapted on that partition, alongside MEvince with evidence memory. Direct Prompt, RAG, and CTIKG receive no additional fitting. Both comparisons use the same 55 evaluation reports. Methods retain their own text processing and prediction rules; the common evaluator parses and deduplicates report-level technique identifiers and applies the same metrics.

C.2 Retrieval Depth

Without the report-level budget used in Figure 2, the full candidate packets cover 329 of 503 exact-ID report–technique associations (65.4%) and 371 of 471 parent-level associations (78.8%). Increasing the per-target retrieval depth from four to eight raises coverage to 66.0% and 80.3%, respectively, while the mean number of distinct candidates per report grows from 109.5 to 115.5. Increasing retrieval depth alone therefore recovers few additional reference labels.

C.3 Structural Traceability Audit

We audit all 438 report–technique assignments accepted by the frozen base run on the 55 evaluation reports. Each has a supporting claim, at least one resolvable evidence unit or group, and rendered evidence text. None of their supporting claims records a blocking proof gap. This audit verifies that the required evidence references and decision records are present and resolvable; it does not evaluate whether the cited behavior is sufficient to establish the technique.

C.4 Document-Verification Case Study

Figure 4 illustrates a Medusa claim removed by document verification. Evidence U3/G1 preserves a report statement about data theft before encryption, but the statement does not identify the transfer protocol. The mapper nevertheless accepts T1048 (Exfiltration Over Alternative Protocol), citing U3/G1 and reporting no proof gap. Without the verifier, this assignment remains in the output. The document verifier rejects it because the candidate was retrieved only as an alternative, has a low retrieval score, and has no matched profile concepts. This removes one exact-ID false positive while leaving the evidence, candidates, and mapping response unchanged.

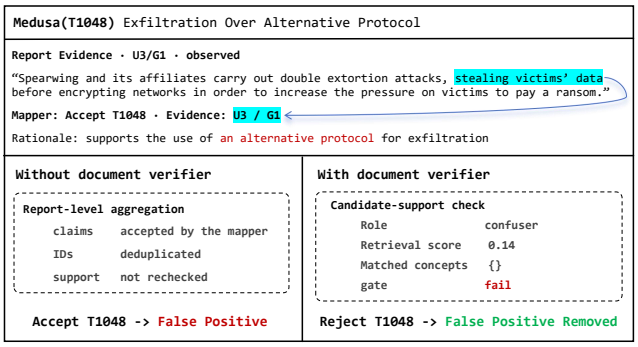

Figure 4: Document verification for T1048.

D Potential Analyst Workflows

The structured output of MEvince supports analyst review beyond a flat label set. For knowledge-base curation, each accepted or abstained technique can be exported with its source URL, quoted spans, evidence status, matched mechanism, and proof gaps. Accepted claims form a review queue; abstentions identify the additional evidence needed. Because the report remains the factual authority, an analyst can reject a mapping without discarding the extracted observation. The same source-linked evidence can provide bounded hypotheses for code or binary analysis—for example, directing attention from a persistence claim to registry-write routines and startup paths. Future studies could assess these downstream workflows through blinded expert review of independent reports, focusing on claim correctness and analyst review time. Evaluating the code-analysis workflow would additionally require paired reports and malware samples.

E Additional Related Work

Threat Behavior and Knowledge-Graph Extraction. iACE analyzes grammatical relations in technical articles to extract indicators of compromise together with their contextual information [29]. EXTRACTOR simplifies report text, resolves references such as pronouns, and constructs provenance graphs connecting system entities through reported actions [40]. ThreatRaptor constructs behavior graphs from extracted indicators and their relations, then synthesizes queries over system audit logs for threat hunting [14]. AttacKG aggregates information across reports to enrich technique templates with different behavioral variants [28].

LLMs for CTI Extraction and ATT&CK Mapping. CTINexus groups entities by type, merges equivalent mentions, and predicts missing relations between subgraphs [6]. CTIKG normalizes triples and uses a checker agent to identify common output errors and request corrections [20]. Fieblinger et al. compare prompting and fine-tuning for CTI triple extraction, using the extracted knowledge for graph construction and link prediction [11]. Fayyazi et al. compare encoder-model fine-tuning with decoder-model RAG for identifying the intended tactics of cyberattack procedures [10]. Guru et al. study LLM-based TTP extraction and embedding-based technique matching for threat-actor attribution [18].

Evidence-Supported Generation and Verification. ALCE evaluates long-form answers with citations, measuring fluency, correctness, and citation quality [15]. Its citation recall measures whether cited passages jointly support a statement, while citation precision identifies irrelevant citations. It uses natural language inference to assess citation support. RARR checks evidence support after generation [13]. It constructs search queries from the output, retrieves evidence, and revises unsupported statements while preserving the rest of the text as much as possible.